

Security Incident Analysis: Web Server Compromise and Malicious Redirect

Simulated Case Study

Incident Summary

During the investigation of yummyrecipesforme.com, a former employee gained unauthorized administrative access through a brute-force attack against an account that was still using a default password. After gaining access, the attacker modified the website's source code, added JavaScript that prompted visitors to download an executable file, and changed the administrative password.

Customers later reported that the legitimate website prompted them to download the file to access free recipes. After running it, their browsers were redirected to greatrecipesforme.com, and their computers began operating more slowly. The incident was reproduced in a sandbox environment using tcpdump, while source-code review and analysis of the downloaded file provided additional evidence of the compromise and redirect behavior.

Technical Analysis

The tcpdump capture first shows the client sending a DNS request for yummyrecipesforme.com. The DNS server returned 203.0.113.22, giving the client the IP address needed to contact the website.

The client then initiated a TCP connection from temporary source port 36086 to the web server's HTTP service on port 80. The capture shows the standard TCP three-way handshake: SYN [S], SYN-ACK [S.], and ACK [..]. Once the connection was established, the client sent GET / HTTP/1.1, requesting the website's root page over HTTP.

Later, the client sent a new DNS request for greatrecipesforme.com, which resolved to 192.0.2.172, and established a separate TCP connection using source port 56378 and destination port 80. The new source port indicates a separate client connection, while the destination service remains HTTP on port 80.

The packet capture confirms that the client began communicating with the second domain, but it does not independently explain why. Source-code review identified the malicious JavaScript that prompted the download, and analysis of the downloaded file identified the redirect functionality. Together, these findings establish the connection between the website compromise and the malicious redirect.

Root Cause and Impact

The primary cause of the compromise was weak privileged-account security. The administrative account still used a known default password, and sufficient controls were not in place to prevent repeated authentication attempts. This allowed the attacker to successfully guess the credential and obtain administrative access.

Because the compromised account had permission to modify the website, the attacker was able to alter production source code, change the administrative password, and expose visitors to a malicious executable. The website owner lost access to the admin panel, while affected users were redirected to the malicious site and reported degraded computer performance.

The incident demonstrates how a weakness at the authentication layer can expand beyond a single compromised account and create broader application and end-user risk.

Security Recommendations

- **Require MFA for privileged accounts.** Administrative access should require more than a password alone, using at least two independent authentication factors to reduce the risk of account compromise when a password is guessed or stolen.
- **Eliminate default and weak credentials.** Default administrative passwords should be replaced before a system enters production. Privileged accounts should use long, unique passwords, and credentials should be changed when compromise is known or suspected.
- **Limit repeated login attempts.** Authentication rate limiting, progressive delays, or carefully configured temporary lockouts can reduce the effectiveness of automated brute-force attacks.
- **Monitor authentication activity.** Successful and failed administrative login attempts should be logged and monitored so that unusually high failure rates or other suspicious activity can be investigated.
- **Reduce privileged exposure.** Apply least privilege and restrict access to administrative interfaces where practical so that fewer accounts and systems can make high-impact changes.
- **Use HTTPS/TLS as additional web hardening.** HTTPS protects web traffic in transit and helps clients verify that they are communicating with the intended server. It would strengthen the site's overall security, although it would not prevent the type of brute-force password attack that caused this incident.